

IoT Security

- IoT security is a technology area that particularly focuses on **protecting connected devices and networks in IoT**. The act of protecting these devices and making sure they don't bring risks into a network is known as IoT security.
- There is **no built-in security on IoT devices**, as IoT devices behave without being noticed by traditional cybersecurity systems and transport data over the internet in an unencrypted manner. Therefore, IoT security is necessary to assist in avoiding data breaches.
- Security was **not considered during the design of IoT devices**. The constant diversity and expansion of IoT devices and communication channels raises the possibility that cyber-attacks may target your company.
- IoT devices were **not built with security in mind**. The ongoing proliferation and diversity of IoT devices and communications channels increases the potential for your organization to be exposed to cyber threats.
- Unfortunately, there is **no way to install security software** on most IoT devices. IoT devices may **even ship with malware on them that infects the network** when they connect. This is why network security is a priority for IoT security.
- Attacks are likely to occur to anything linked to the Internet at some time. From the IoT devices, Attackers **may utilize remote access** to steal data by using a variety of strategies, including credential theft and vulnerability exploitation.

Types of IoT Security

IoT security encompasses a **multi-layered approach** to protect devices, networks, and data. It involves **both user and manufacturer responsibilities**.

(i) Network Security

This focuses on safeguarding the overall IoT network infrastructure. It involves:

- **Establishing a Strong Network Perimeter:** Implementing firewalls, intrusion detection systems, and access controls to prevent unauthorized entry.
- **Enforcing Zero-trust Architecture:** Assuming every device and user is potentially malicious, requiring continuous verification.
- **Securing Network Communication:** Encrypting data transmitted between devices and using secure protocols.

(ii) Device Security

This centers on protecting individual IoT devices.

- **Embedded Security Agents:** Employing lightweight software to monitor device behaviour and detect anomalies.
- **Firmware Hardening:** Ensuring device software is free from vulnerabilities through rigorous testing and updates.
- **Secure Boot Process:** Verifying the integrity of the device's operating system before startup.

(iii) Data Security

This safeguards the information generated and transmitted by IoT devices.

- **Data Encryption:** Protecting data both at rest and in transit using strong encryption algorithms.
- **Data Privacy:** Implementing measures to protect sensitive information from unauthorized access.
- **Data Integrity:** Ensuring data accuracy and consistency through checksums and other techniques.

How Does IoT Security Work?

- IoT devices are any devices that can store data by connecting to the cloud.
- IoT devices **need a special set of cybersecurity guidelines** because of how they differ from conventional mobile devices. They **lack the benefit of built-in security guidelines** seen in mobile operating systems like iOS and Android.
- **A lot of information is stored in the cloud**, if an attacker manages to get access to the user's account, it might be exploited for identity theft or privacy invasion.
- Although there isn't a single solution for IoT security, cybersecurity experts have made it their mission to **inform manufacturers and developers about secure coding practices** and how to **strengthen cloud activity defences**.

Importance of IoT Security

- Cyberattacks are a continual concern because of the **unusual way that IoT devices are manufactured** and the **enormous volume of data** they process.

- IoT security is necessary, as evidenced by some high-profile cases in which **a common IoT device** was an advantage to **breach and attack the wider network**.
- **Strong IoT security is desperately needed**, as seen by the regular threat of vulnerabilities, data breaches, and other dangers related to the use of IoT devices.
- IoT security, which encompasses a broad variety of tactics, strategies, protocols, and activities aimed at reducing the growing IoT vulnerabilities of contemporary firms, is essential for corporations.

Benefits of IoT Security

Below are some benefits of IoT Security.

- **Network Protection:** By identifying and preventing threats like Distributed Denial of Service (DDoS) attacks, which can disrupt and harm the whole network, security solutions may aid in the protection of the IoT as a whole.
- **Privacy Protection:** These solutions shield user privacy from unauthorized surveillance, data theft, and device tracking by protecting IoT devices.
- **Scalability:** Strong IoT security is scalable in that it can keep up with the expansion of an organization's IoT environment and guarantee security protocols work even as the number of connected devices rises.
- **Device Protection:** IoT security ensures the lifetime and correct operation of devices by protecting them from viruses, hacking, and unauthorized access.

IoT Security Issues and Challenges

There are many challenges facing enterprises when dealing with IoT security.

IoT Security Challenge



- **Weak Authentication and Authorization:** IoT devices often rely on weak authentication and authorization practices, which makes them vulnerable to threats. For example, many devices use **default passwords** making it easier for hackers to gain access to IoT devices and the networks they use for communication. In addition, **rogue IoT devices (i.e., undetected)** that are connected to the network can be used to steal data or launch attacks.
- **Lack of Encryption:** The overwhelming majority of IoT device network traffic is **unencrypted** making confidential and personal data vulnerable to a malware attack such as ransomware or other form of data breach or theft. This includes IoT devices used for medical imaging and patient monitoring, as well as security cameras and printers.
- **Vulnerabilities in Firmware and Software:** The short development cycles and low-price points of IoT devices limit the budget for developing and testing secure firmware. Without this built-in IoT security, IoT devices are vulnerable to the most rudimentary forms of attack. From firmware to software and third-party apps—millions of devices are affected by vulnerabilities in standard components. Plus, network environments can be compromised by vulnerable web apps and software for IoT devices. Whether it is a new threat or old malware, without IoT security, all types of vulnerabilities make IoT devices good targets for savvy bad actors to stage cyberattacks.
- **Insecure Communications Protocols and Channels:** IoT devices are often connected to the same network as other devices, which means that an **attack on one device can spread to others**. Lack of network segmentation and oversight of the ways IoT devices communicate makes them easier to intercept. For example, not long ago the automotive industry's adoption of Bluetooth technology in IoT devices resulted in a wave of data breaches that made the news. As well, protocols like HTTP (Hypertext Transfer Protocol) and API—are all channels that IoT devices rely on and cyber criminal's exploit.
- **Difficulty in Patching and Updating Devices:** IoT manufacturers don't focus on building IoT security into their devices to make hardware tamper proof and secure. Many IoT devices are **not designed to receive regular IoT security updates**, which makes them vulnerable to attacks. Without built-in IoT security it's difficult to ensure secure upgrades, provide firmware updates and **patches** (Patching is the process of applying small, specialized code updates to software or operating systems to fix security vulnerabilities, repair bugs, or improve performance), and perform dynamic testing. Therefore, the onus is on the organization to protect its IoT devices and network environment from cyber threats.

Which Industries are Most Vulnerable to IoT Security Threats?

Cyberattacks pose significant risks to various industries.

(i) Manufacturing

The manufacturing sector has become a prime target of cybercriminals since its wide dependency on interconnected systems and supply chains is at an all-time high. The most widespread threats are:

- **Industrial Spying:** This refers to an act where competitors or nation-states that steal or attempt to steal a company's intellectual property, product designs, or even the way in which a particular product is being manufactured.
- **Supply Chain Attacks:** Suppliers or third-party vendors are compromised to get access to the target organization.
- **Ransomware:** Critical systems are encrypted, and in return for their restoration and hence return of operations, a huge ransom is demanded, hence financial loss and production disturbance.
- **IoT Vulnerabilities:** All kinds of vulnerabilities that exist in industrial IoT devices are exploited to interrupt operations or steal data.

(ii) Finance and Insurance

The financial sector has been of interest to each attacker, for the reason that it contains sensitive financial information and huge amounts of money. The various threats posed against them are:

- **Fraudulent Activities:** Entail financial fraud, including identity theft, account takeover, and fraudulent transactions.
- **Cyber Spying:** Financial data, trade secrets, customer information can be stolen for competitive advantage.
- **Ransomware:** Bringing financial services to an absolute standstill, entailing huge financial losses and reputational damage.
- **Insider Threats:** Those people who have some kind of access to sensitive information may bring along certain risks because of negligence or malicious intentions.

(iii) Energy and Utilities

The energy sector provides critical services and represents high-value targets. Potential threats include:

- **Cyber-physical Attacks:** These are attacks aimed at IT and OT systems (Information Technology (IT) manages data and digital communication,

while Operational Technology (OT) controls physical machines and industrial processes) with the view to disrupt power generation, distribution, or transmission.

- **Data Breaches:** Exposure of sensitive customer information, financial data, and operational data.
- **Spying:** Intellectual property, trade secrets, and critical infrastructure information are stolen.
- **Sabotage:** This includes attacks on infrastructures, which cause disruptions of operations, resulting in blackouts and losses of production.

(iv) Retail

Processing vast amounts of customer data and transacting thousands of sales daily, the retail industry becomes a more tantalizing target for attackers by the day. Some common threats include:

- **POS Attacks:** Stealing payment card data either via malware or through skimming.
- **Data Breaches:** Exposure of personal information of customers, which can lead to identity theft and financial losses.
- **Supply Chain Attacks:** Targeting suppliers or logistic providers to cause disruption in its operations or stealing data.
- **E-commerce Fraud:** It includes unauthorized access to online shops and processing fraudulent orders and crimes related to payment.

(v) Healthcare

The healthcare sector contains sensitive information about the patients, making it one of the most prized targets for cybercriminals. Some of the important threats include:

- **Ransomware:** This could disrupt patient care, followed by financial loss and reputational damage.
- **Data Breaches:** Exposure of patient records, including personally identifiable information, medical history, and financial data.
- **Insider Threats:** Those employees or contractors who have access to patient data and become a source of risk owing to negligence or malice.
- **Medical Device Vulnerabilities:** The exploitation of medical devices for vulnerabilities will then allow the disruption of operations or data theft.

(vi) Public Administration

Governmental organizations manage sensitive information, critical infrastructure, and national security; therefore, they are susceptible to the following threats.

- **Cyber Spying:** It involves the theft of classified information, intellectual property, and national security secrets.
- **Disinformation and Propaganda:** The spreading of fake information in order to change opinion, public opinion, or destroy confidence in government.
- **Ransomware:** Affecting government services that disrupt financial operations and attack the reputation.
- **Supply Chain Attack:** To gain access to sensitive information, attack the weakest link in the supply area, which includes government contractors or suppliers.

(vii) Education and Research

Educational institutions store data of sensitive nature about all their students and employees, besides data from lucrative research, all being a doomed target. These threats include:

- **Data Breaches:** Personal data exposure of students, employees, financial data, and academic records.
- **Property Theft:** Theft of research data, patents, and academic publications.
- **Ransomware:** This disrupts all the campus operations, including online learning and all the administrative systems.
- **Insider Threats:** Insider threats of the category of students, faculty, or staff are in line with sensitive information risks.

Which IoT Devices are Most Vulnerable to Security Breaches?

Some IoT devices are more vulnerable than others due to factors like processing power, connectivity, and the sensitivity of data they handle. Some of the most vulnerable IoT devices are follows:

(i) Home IoT Devices

- **Smart Cameras:** This device mostly comes with weak default passwords and less good encryption. It can also be easily hacked and used for spying purposes.
- **Smart Speakers:** Even though they are voice-controlled per se, they can turn out to be a potential target for eavesdropping and data theft.
- **Smart TVs:** Web-connected; can be vulnerable to malware, data breaches, and adware.

(ii) Wearable Devices

- **Smartwatches and Fitness Trackers:** Even though these devices are majorly used to collect the least amount of personal data, this kind of sensitive information might be discovered upon infringement.
- **Medical Devices:** Pacemakers and insulin pumps—which, when hacked, may lead to fatal results.

(iii) Industrial IoT Devices

- **ICS (Industrial Control Systems):** These are utilized in the control of critical infrastructure, such as power plants and factories, and may become targets for cyber-attacks that can cause physical damage or disruptions.
- **Connected Vehicles:** Connectivity in vehicles has increased with years; therefore, so have the chances of car hacking, which could result in remote car control or data theft.

(iv) Other Vulnerable Devices

- **Home Routers:** As the gateway to your entire home network, a weak router can give way to the compromise of all devices connected to it.
- **Smart Thermostats:** It looks harmless, but they could have actually been part of a botnet or even used as spies over your home.

Which Industries Need IoT Security?

IoT Security thus has a huge role in various industries because most of them are getting interconnected. Some of the sectors that really need strong IoT Security:

- **Healthcare:** Even medical devices, like pacemakers, insulin pumps, and remote patient monitoring systems, are susceptible to cyber-attacks that may result in the loss of lives.
- **Manufacturing:** Cyber-attacks paralyze ICS/OT environments of critical infrastructure and bring with them enormous financial losses and safety hazards.
- **Energy and Utilities:** This sector represents critical infrastructure that is accompanied by a high utilization of IoT devices, powering power grids and water treatment plants, among others, making them very attractive targets for cyber-attacks that may have catastrophic consequences.
- **Transportation:** Autonomous vehicles, smart traffic systems, and connected cars use vast volumes of data, making them quite vulnerable to hacking and subsequent data breaches.

- **Financial Services:** IoT-related devices used in banking, payments, and financial transactions process sensitive financial data and hence require robust security measures against fraud and data theft.
- **Retail:** Point-of-sale systems, inventory management data, and customer data are all at risk if IoT devices are compromised.
- **Government:** IoT security is necessary for critical infrastructure, national security, and citizen data.
- **Agriculture:** Cyber-attacks on smart farms and IoT-enabled equipment can affect food production and its supply chain.
- **Building Automation:** Security is required for smart buildings with IoT-enabled systems against unauthorized access and data breaches.

How to Protect IoT Systems and Devices?

Here are the steps to secure IoT systems and devices.

- **DNS Filtering:** Using the Domain Name System to restrict harmful websites is known as DNS filtering. When DNS filtering is added to a network including IoT devices, it stops such devices from connecting to domains that are not authorized.
- **Encryption:** Without encryption, data transfers between IoT devices are susceptible to on-path and external attackers while travelling over the network. Consider encryption as a means of protecting a letter's contents during transit via the postal service, similar to an envelope.
- **Device Authentication:** IoT devices are connected to servers, other networked devices, and one other. All connected devices must undergo authentication to prevent unwanted inputs or requests from third parties.
- **Security of Credentials:** If at all feasible, IoT device admin credentials must be updated. It is recommended to avoid sharing login credentials between various apps and devices, instead every device should have its password. In doing so, credential-based attacks are less likely.

Tools to Secure IoT Devices

- **ForeScout Platform:** This protects and ensures on a network the consent of all managed and unmanaged devices, including IT, IoT, and OT devices, using zero trust principles.
- **Microsoft Defender for IoT:** Microsoft Defender for IoT helps enterprises manage, discover, and protect their IoT and OT devices. Extra features include network and device threat monitoring around the clock, identifying every asset and device.

- **Asimily:** Asimily is a complete IoT security platform that focuses on medical and laboratory equipment.
- **AWS IoT Device Defender:** AWS IoT Device Defender is Amazon's IoT security management service. AWS IoT Device Defender allows administrators to authorize security measures such as authentication and permission.

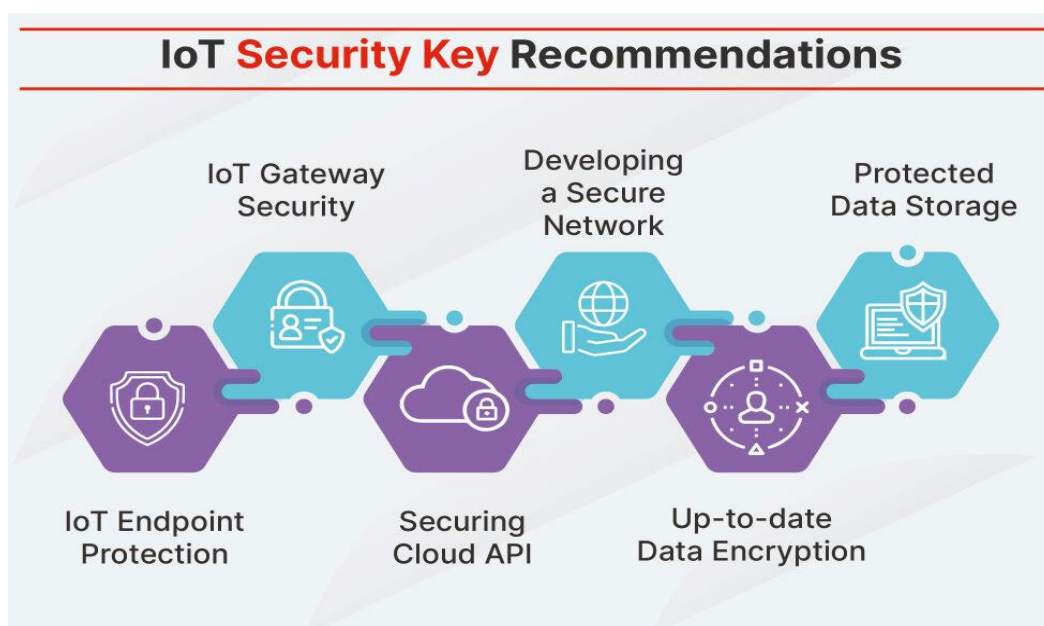
How To Address IoT Security Requirements?

IoT and security requirements can only be accomplished with an **integrated solution** that delivers **visibility, segmentation, and protection** throughout the entire network infrastructure, such as a holistic security fabric approach. Your IoT security **must contain the following key abilities:**

- **Learn:** With complete network visibility, security solutions can authenticate and classify IoT devices to build a risk profile and assign them to IoT device groups.
- **Segment:** Once the enterprise understands its IoT attack surface, IoT devices can be segmented into policy-driven groups based on their risk profiles.
- **Protect:** The policy-driven IoT groups and internal network segmentation enable monitoring, inspection, and policy enforcement based on the activity at various points within the infrastructure.

Key Recommendations for IoT Security Best Practices

Best practices for IoT security include:



(i) IoT Endpoint Protection

- A critical step to securing IoT devices is hardening them through IoT endpoint protection. **Hardening endpoints** involves **plugging vulnerabilities in high-risk ports**, such as Transmission Control Protocol (TCP) and User Datagram Protocol (UDP), wireless connections, and unencrypted communications. It is also vital to protect devices from malicious code injection.
- Endpoint protection enables organizations to safeguard their networks against advanced attacks, such as the latest malware and ransomware strains. It also **secures devices at the network edge**, allowing security teams to gain complete visibility of their network, obtain real-time insight into which devices are connected to it, and reduce their attack surface.

(ii) IoT Gateway Security

- Enterprises can also protect their IoT devices using IoT gateway security, which **enforces internet access policies** and **prevents unwanted software**, such as malware, **from accessing user connections**.
- A Secure Web Gateway (SWG) includes vital features like application control, deep Hypertext Transfer Protocol Secure (HTTPS) and secure sockets layer (SSL) inspection, remote browser isolation, and Uniform Resource Locator (URL) filtering. This is crucial as organizations migrate to the cloud and enable remote connections. It helps to prevent security risks for web-based traffic and protects IoT devices from external and internal cyberattacks.
- Connections can also be secured by threat monitoring solutions that prevent data leaks and virtual private networks (VPNs), which encrypt browsing data and prevent users' internet activity from being snooped upon by hackers.

(iii) Securing Cloud API

- Cloud application programming interfaces (APIs) enable IoT applications and systems to communicate and integrate. They play a significant role in connecting services and transferring data. This means a **broken or hacked API could result in a massive data breach**. It is therefore vital to secure cloud APIs through the use of authentication, encryption, tokens, and API gateways.

- For example, web API security secures data as it is transferred across the internet, and REST APIs encrypt data and internet connections to secure data shared between servers and devices.

(iv) Developing a Secure Network

- Developing a secure network connection ensures **adequate access control is in place**. This guarantees only secure, authenticated, or verified devices are allowed to connect to the network.
- Network security begins with **setting up a secure firewall**. It is then essential to deploy security tools and practices like **multi-factor authentication (MFA)** that secure devices every time users attempt to connect to the network. It is also crucial to keep authentication keys safe, install updated antivirus and antimalware software, and continuously monitor network activity to keep devices and users secure.

(v) Up-to-date Data Encryption

- Encryption is critical to securing data in motion when it is transferred between devices or onto the internet. IoT encryption is typically through **asymmetric and symmetric encryption methods**.
- Symmetric encryption uses a single cryptographic key to encrypt and decrypt data, while asymmetric encryption uses public and private keys and offers an enhanced level of security.

(vi) Protected Data Storage

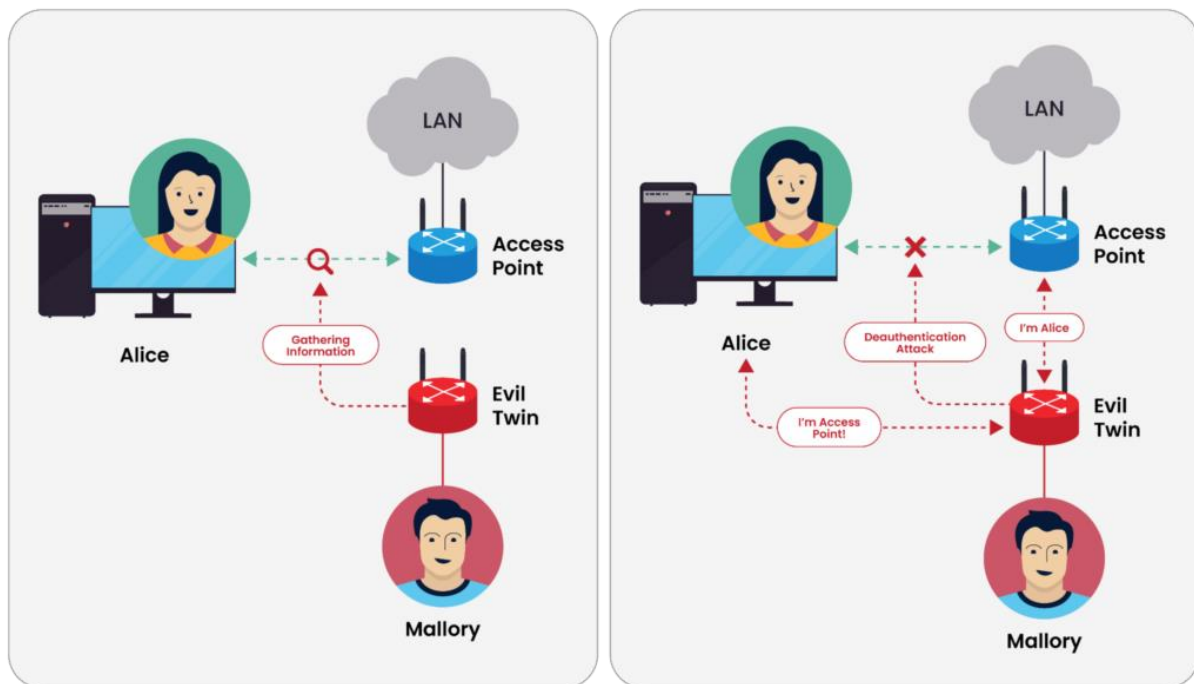
- IoT devices and sensors are creating **ever-increasing volumes of sensitive data**, from financial and personal information to biometric data, **stored on cloud-based or hardware storage solutions**. So, it is crucial to have **security in place to ensure this information is secure** when being stored or transferred.
- Protecting data storage includes **effective, updated antivirus solutions** and monitoring and scanning tools that **cover the network against real-time IoT threats**. It is important to have features like flexible reporting and scanning alongside notification systems, antimalware, and a centralized management console that provides deep visibility into network activity.

Common Attacks Against IoT Networks

Now that we understand the networking and cybersecurity challenges IoT devices pose, let's review how threat actors can exploit IoT vulnerabilities to launch cyberattacks.

(i) Man in the Middle Attack (MITM)

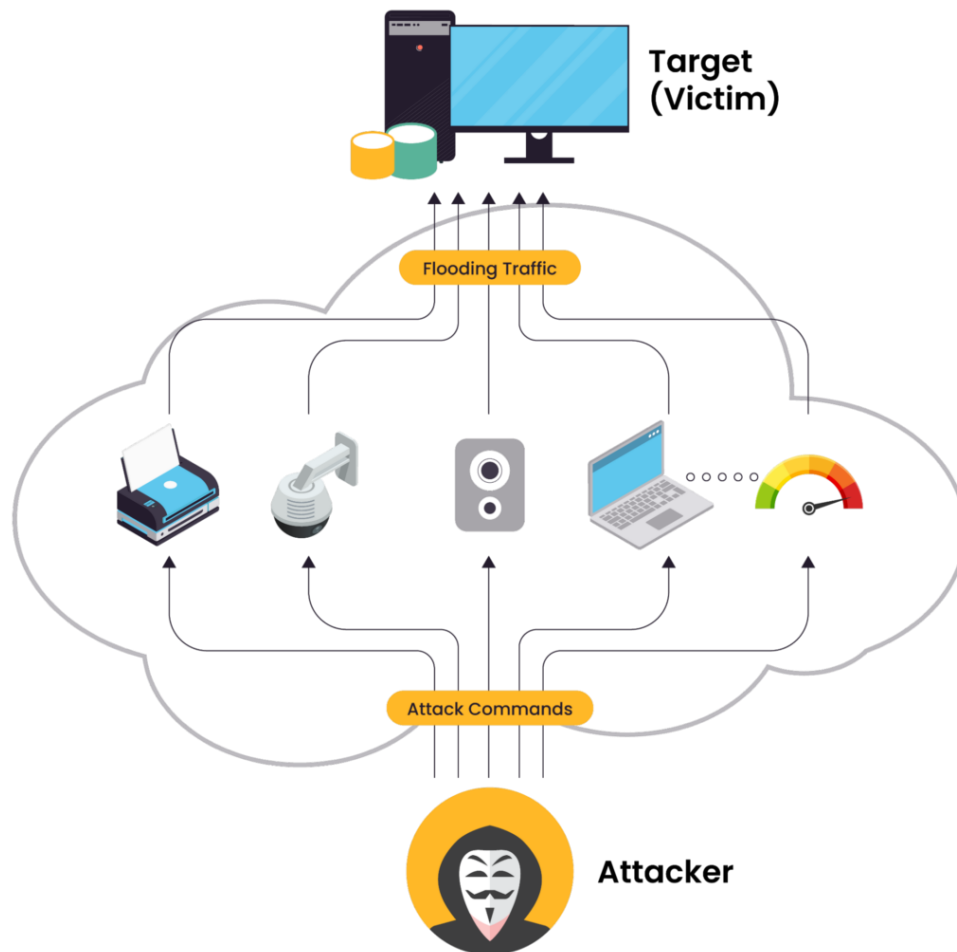
A man-in-the-middle (MITM) attack is a cyberattack where an **attacker secretly intercepts and possibly alters the communication** between two parties who believe they are directly communicating. While this attack **may target any network-connected devices** that a malicious actor can communicate with, **IoT devices are more vulnerable** to these attacks as they lack support for advanced security features.



Let's consider a WLAN example. Recent Wi-Fi protocols support mutual authentication, which requires the user to provide credentials to authenticate and the server or network to provide credentials and proof of trust before they start communicating. The concept of mutual trust is essential in current authentication frameworks like EAP-PEAP and EAP-TLS. However, since many IoT devices don't support these protocols, they may rely on outdated and vulnerable protocols like WPA2-Personal with PSK to connect to the network. These vulnerable protocols lack any reliable mechanism to verify network identity, and they rely on weak PSK that can be easily cracked by hackers who may impersonate a valid AP by broadcasting an identical SSID with the same PSK (Evil Twin attack) and intercepting communication between IoT devices and the network.

(ii) Distributed DoS (DDoS) Attacks

IoT devices can be vulnerable due to weak security measures, such as default or easily guessable passwords and outdated firmware. They can be **hijacked into a botnet** that **launches a Distributed Denial-of-Service (DDoS)** attack. In a DDoS attack, these **compromised devices simultaneously flood a target with excessive traffic, effectively taking it offline.**



One well-known example is the **Mirai botnet**. In 2016, Mirai scanned the internet for IoT devices with weak security. Once compromised, it took control of devices such as IP cameras, DVRs, and routers. The botnet then initiated a massive DDoS attack against Dyn, a major DNS provider, causing widespread internet outages and impacting popular websites like Twitter, Netflix, and Reddit. This attack demonstrated how a significant number of insecure IoT devices could be transformed into a powerful force for disruption.

(iii) Spoofing Attacks

With weak authentication and poor encryption algorithms, IoT devices are at risk of spoofing attacks. In these attacks, a **malicious user introduces a rogue device on the network that impersonates an IoT device** by exploiting weak authentication methods, such as MAC authentication, or by cracking vulnerable encryption protocols like WPA-2 PSK. Attackers can use these rogue IoT devices to gain unauthorized access to your network, posing significant security risks. They can **exfiltrate sensitive data, disrupt operations through denial-of-service attacks, propagate malware, and compromise system integrity.**

You can protect your network from these attacks by implementing more secure authentication protocols, such as certificate-based authentication like EAP-TLS. Additionally, avoid using MAC address filtering as your primary authentication method since MAC addresses can be easily spoofed. Organizations should also avoid using WPA/WPA2 PSK, which threat actors can easily crack with tools like Aircrack-ng.

(iv) Eavesdropping & Data Theft

IoT devices collect sensitive information from your organization, such as telemetry, video, and sensor readings. This makes them a target for eavesdropping and data theft attacks, mainly if they send or store traffic unencrypted or using a weak encryption algorithm. They are also subject to supply chain attacks, where compromised or counterfeit devices can be used by third parties to launch attacks against your network or exfiltrate valuable information.

(v) Lateral Movement

Malicious actors who want to access your network may select IoT devices as an entry point into more critical areas of the network. In these cases, they **compromise IoT devices as an entry point to move laterally within a network and attack more valuable assets.** In these attacks, malicious users find IoT devices easy targets as they lack advanced security features and are vulnerable to exploits.

How to Improve IoT Network Security

Improving IoT security posture is essential to enhancing the overall security posture of the entire network. This section will focus on the techniques and controls that empower organizations to strengthen their IoT network security.

(i) Visibility

Security begins with visibility; **you cannot secure what you don't see**. With IoT devices introduced to the network by different departments in your organization, you need to **have the necessary features and tools** in your network that can scan, profile, and list these devices, providing you with **information about device types, operating systems, and device families**. This helps you build your network and security strategies around the types of devices connecting to your network.

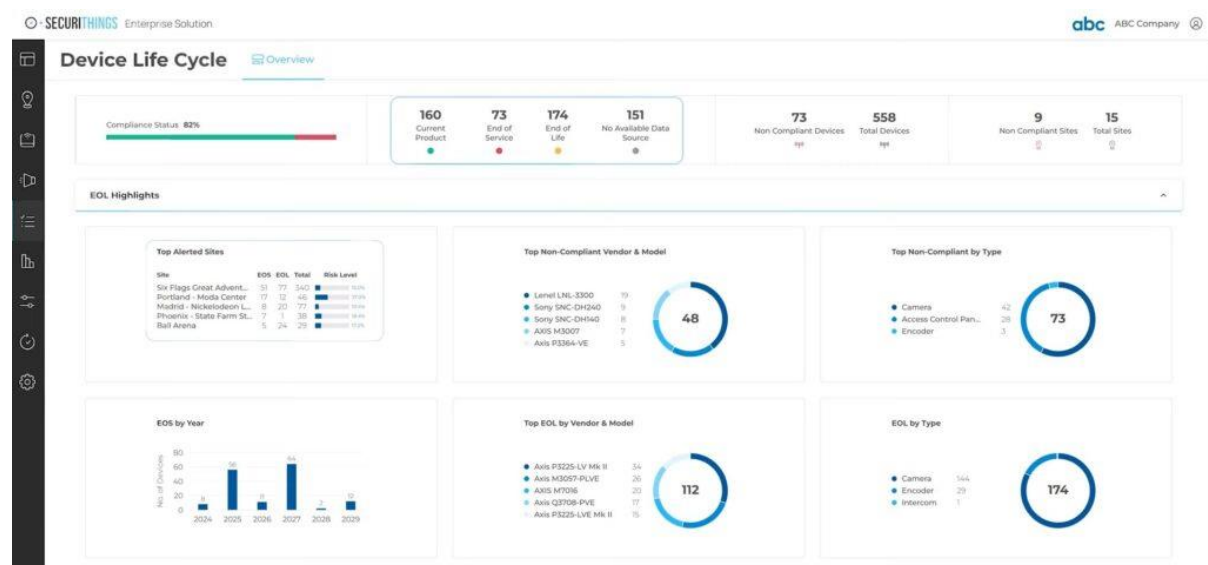
Visibility also includes **maintaining an up-to-date inventory of IoT devices connected to your network and details about manufacturer information, ownership, and physical location**. This can be combined with your network access control, scanning, and profiling tools to help track these devices and identify any rogue devices connected to your network. SecuriThings offers a comprehensive IoT and physical device security management platform, which includes inventory discovery, automated patch management, password rotation, regulatory compliance reporting, and more.



(ii) Device Life Cycle Management

With the increasing number of IoT devices, you may lose track of what has been added to your network. This becomes a security concern when some of these **devices reach the end of their life cycle and stop receiving new features or security patches** from the manufacturer. These “end-of-life” devices, running old and unpatched software, are considered easy targets for hackers and malicious actors.

To mitigate this risk, you need to **keep track of all End of Life (EOL)** announcements from different vendors and compare part numbers with what you have in your environment. This task becomes more challenging when you have a large number of IoT devices from different vendors and multiple part numbers, as they are purchased at different times. For this reason, it is important to implement monitoring platforms with built-in inventory and life-cycle management, such as SecuriThings, to track and assess the life-cycle status of all devices in your environment. This allows you to replace old or obsolete devices before they reach their end-of-life state as specified by the manufacturer. The figure below shows the SecuriThings “Device Life Cycle” dashboard.



(iii) Monitoring

Monitoring is an essential part of your network security and incident management process. The **faster you detect an attack, the more effectively you can isolate it, eradicate threats, and recover systems.** Your network should include tools such as SIEM, EDR, XDR, and logging for effective monitoring and alerting in the event of any compromise, exploit, or attack.

With many network attacks initiated by compromising IoT devices, you also need to consider monitoring and managing these devices as part of your overall network security strategy. The challenge is that these devices follow different architectures, and every manufacturer has his own monitoring and management tools with different feature sets, which makes this subject challenging. You need a single pane of glass solution that provides you with a unified view of all IoT devices in your environment, with the option to manage them and verify their compliance with your security policies, such as password complexity, password expiration policies, authentication protocols, encryption algorithms, and hardware and software compliance with regulations and policies.

(iv) Patching

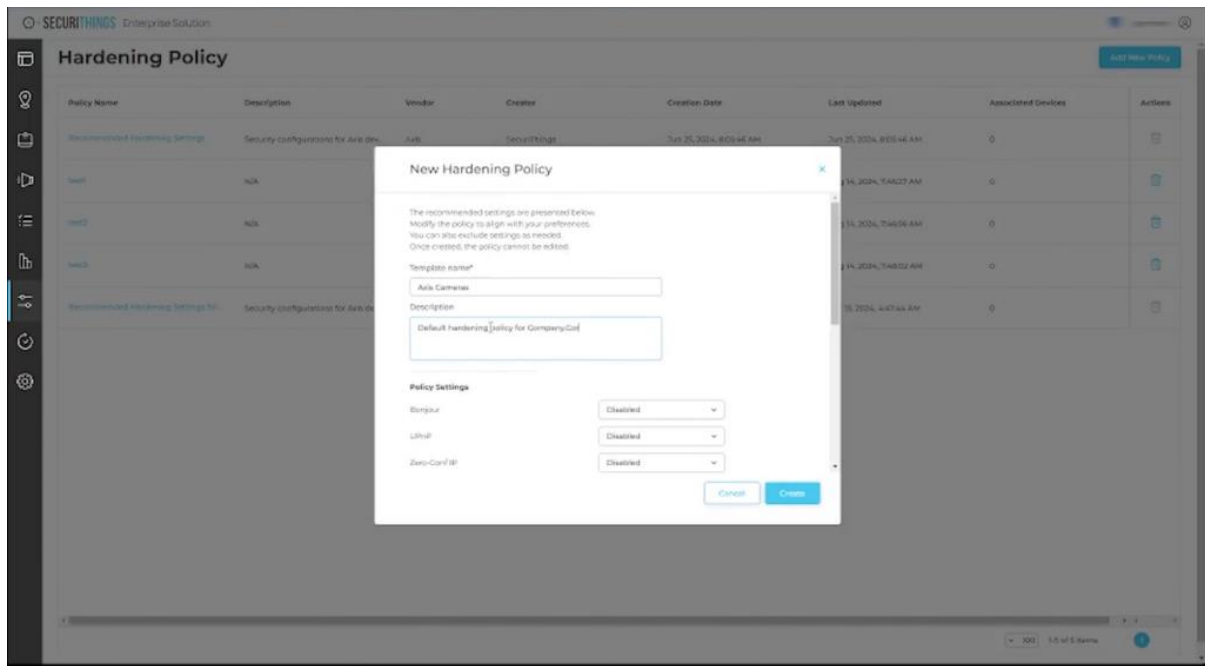
While you might have patching solutions for common enterprise operating systems such as Windows, Linux, and macOS, these solutions are often ineffective for many IoT devices. As we discussed before, one of the challenges with IoT devices is in their various operating systems, which are embedded or manufacturer-specific in many cases. The other challenge is that **IoT devices operate 24/7, and arranging a maintenance window to upgrade them is difficult**. Many IoT manufacturers offer patching solutions or provide patches through their websites, but integrating all these sources and tools into your software patching strategy can be cumbersome.

To effectively manage your IoT device operating system and patching requirements, you need a unified platform that monitors published CVEs, correlates them with your specific environment, highlights relevant vulnerabilities, and coordinates a patching schedule for your IoT devices. Solutions like SecuriThings offer CVE feeds and OS patching as part of their IoT monitoring and management platform, which can help you in your patching process.

(v) Device Hardening

IoT devices come from the manufacturer with default settings that, in many cases, don't follow best practices. Sometimes manufacturers want devices to be easy to discover and connect to with default settings, but this should change once devices are connected to the enterprise network. The **process of modifying default device settings to make them more secure is called “hardening”**. The hardening process includes disabling insecure protocols, such as Telnet, HTTP, SNMP v1/2, and other management and communication protocols that are considered insecure. It also includes configuring more complex passwords, among other recommended configuration changes, to make IoT devices more secure and comply with industry and organizational security requirements. This process of hardening becomes more challenging with the large number of IoT devices and different capabilities and configuration requirements for each device type.

To address this challenge, platforms like SecuriThings provide a tool for configuring hardening policies. The tool applies these policies to different device types based on the communication and configuration steps for each type. The figure below shows the process of creating a sample hardening policy. This policy can later be applied to one or multiple device types for better security and consistency.



(vi) Network Security Controls

IoT device security is part of overall network security. To secure IoT devices, you must follow risk management frameworks and best practices and apply the necessary security controls. You also need to **deploy network security products** like next-generation firewalls (NGFW), intrusion detection systems (IDS), and intrusion prevention systems (IPS), and enable advanced security features like deep packet inspection (DPI), URL filtering, application visibility and control, behaviour analytics, and the latest security features. You may need to **apply higher security standards** in networks or segments where IoT devices are connected.

Security awareness is also an essential part of your overall network security strategy. Educating users (both IT and non-IT employees) about the risks of adding unmanaged or uncontrolled devices into the network can also help improve your overall IoT network security.

(vii) Password Protection

Passwords are added to prevent unauthorized access to the device, but in many cases, they can be a vulnerability if they do not comply with certain standards and if they are not changed frequently. Many IoT-specific attacks, like Mirai, targeted IoT devices connected to the network with default or simple passwords. Your IoT security policy should include modifying default credentials before connecting IoT devices to the network and scanning these devices for any default or guessable passwords. As explained the need of password rotation, a tool like

SecuriThings will help enforce such a policy across all the IoT devices in your environment.

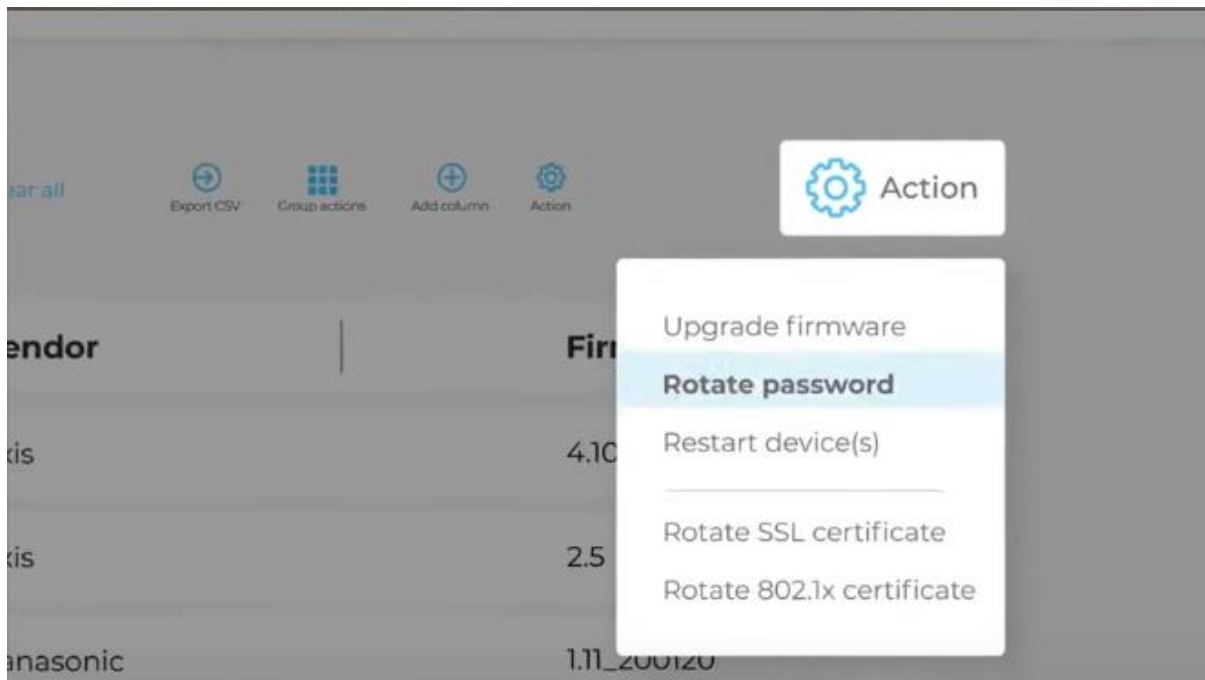
The same applies to WLAN PSK. While WPA3 provides more secure protocols for WLAN access, many IoT devices only support outdated and vulnerable protocols. More complex PSK techniques, such as MPSK, frequent key modification, more granular segmentation, and strict security controls within this network segment, may help reduce risks. However, considering more secure protocols should be part of your strategy when purchasing new IoT devices or upgrading current ones.

(viii) Network Access Control

As part of your zero-trust policy, organizations must ensure that only authorized devices are connected to their network. Solutions like **network access control (NAC) implement the authentication, authorization, and accounting (AAA)** framework to verify and authenticate each device before allowing it into the network. These NAC solutions support multiple authentication protocols, and the security of your NAC department relies on the protocol you select for authentication.

One option is MAC authentication or MAC filtering, but since MAC addresses can be easily detected and spoofed, you should never consider a MAC address as your authentication credential. Administrators should consider more secure techniques like username/password, but they require user interaction and come with risks like simple passwords and password leaks.

Authentication protocols based on digital certificates have proven more secure and scalable for IoT devices. However, they require special tools and protocols to issue certificates from a trusted root CA and install and renew certificates before expiration. Teams must also monitor certificates for any revocations or expired certificates and ensure that their NAC and IoT management solutions are integrated to automate the lifecycle management of IoT device digital certificates. To automate certificate management on IoT devices, solutions like SecuriThings can help rotate 802.1X and SSL certificates from a central location. The figure below shows some of the features of SecuriThings when it comes to password and certificate rotation.



(ix) Segmentation

Even with robust security controls in place, attackers can sometimes find vulnerabilities faster than you and exploit them to compromise one of your IoT devices. In this case, they **attempt to move laterally to more valuable assets** in your network, **using the compromised IoT device** as a pivot point. In some cases, they leverage it to compromise additional IoT devices and control them from a remote command and control center, using them in a coordinated attack against other resources.

Implement network segmentation to limit the impact of such an attack and easily isolate compromised network segments in case of a security incident. A network segment can be a subnet or a VLAN, or even each device can be in its own micro-segment. **Organization-critical assets should be in a separate segment or segments, and strict security controls should be applied in one or multiple layers** to allow only verified and authorized requests into that segment.